SECURITY NINJA GERMANY



Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

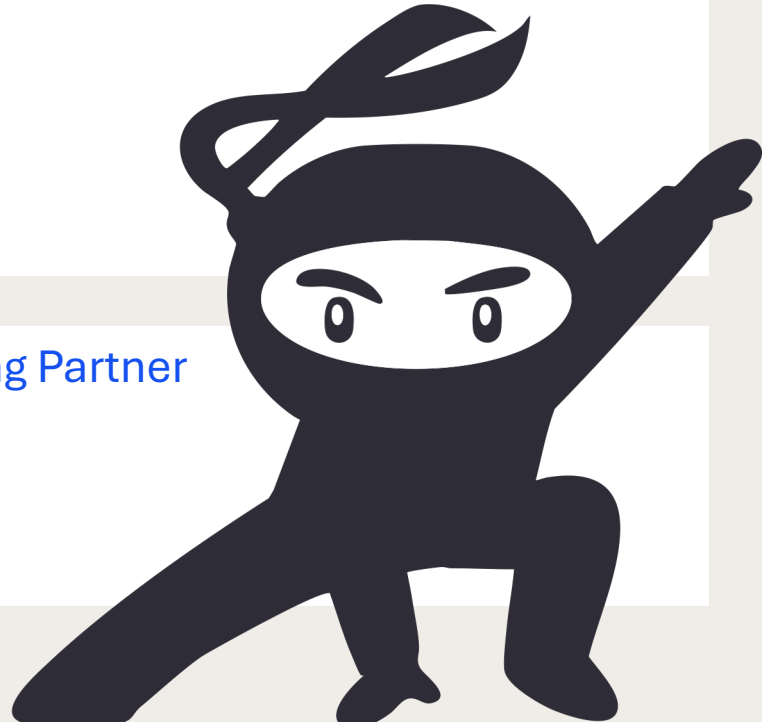
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



Beyond no Return:
Preparing Your Organization for Cyber War

Miska Kytö

About Miska Kytö

Security Architect @ Zure 🦖

Helsinki, Finland 🇫🇮

miskakyto.fi🔗



Microsoft MVP, SIEM & XDR

Active Reservist 🪖

linkedin.com/in/miskakyto

SECURITY NINJA GERMANY

Agenda

What you'll hear about today

- Understanding the threat landscape
- Seeing through the eyes of the attacker
- How to make the attackers hate you
- OPSEC
- Real-life examples

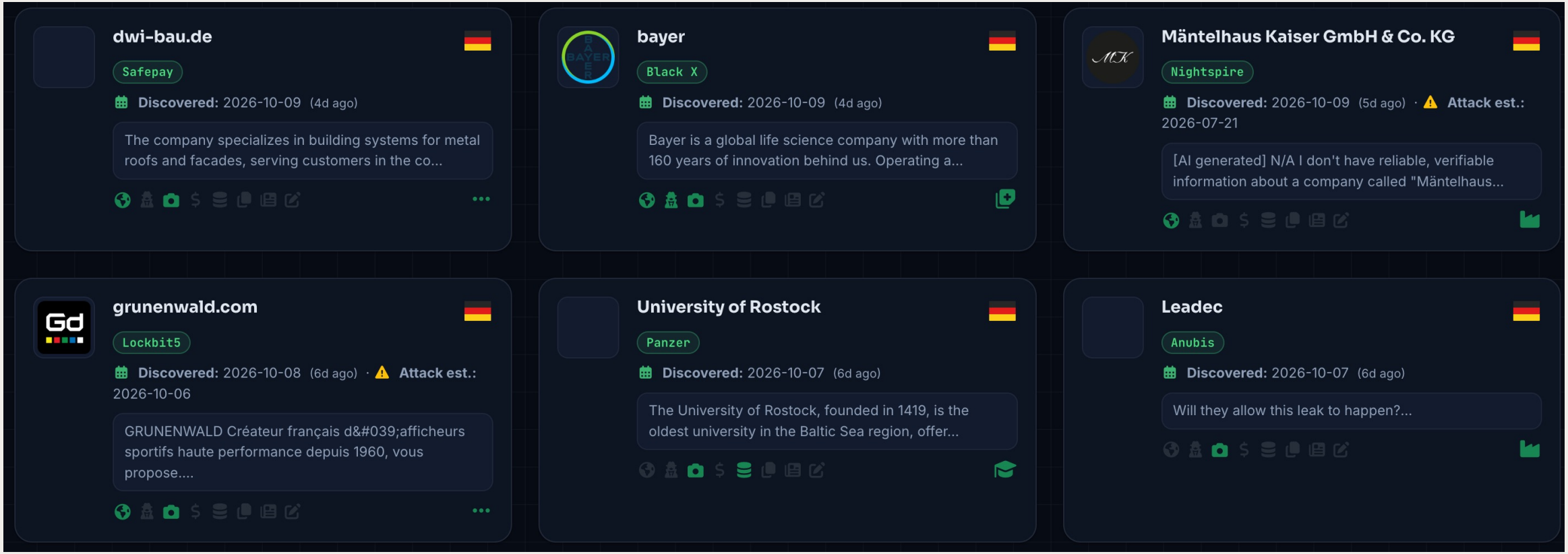
SECURITY NINJA GERMANY

Threat Landscape

What do we need to defend from?

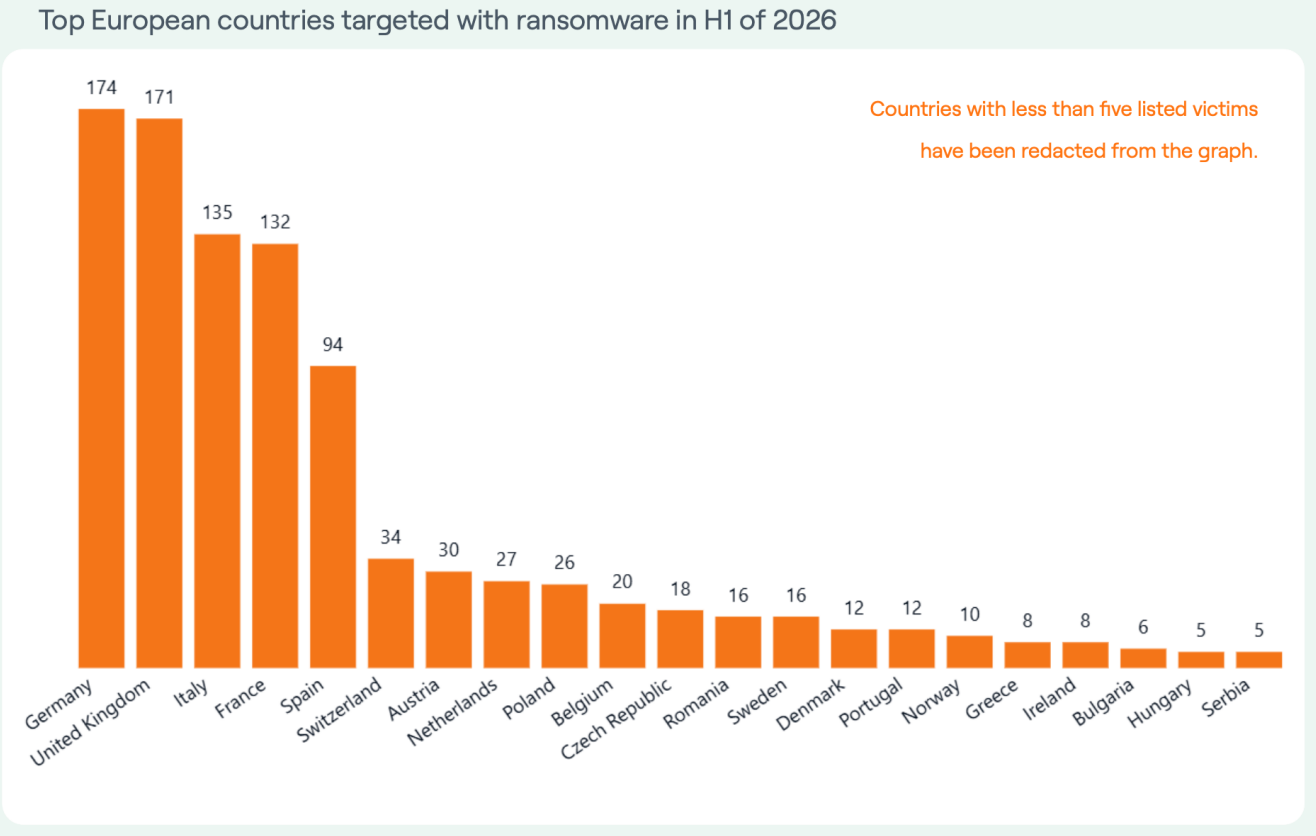


Cybercrime / Ransomware



https://ransomware.live/country/DEU

Cybercrime / Ransomware



NetNordic Mid-year Threat Intelligence Report 2026

Size	2023	2024	2025
1-50	24%	15%	50%
51-500	25%	37%	29%
501-5K	34%	30%	17%
5k+	17%	18%	4%

Table: Percentage of Ransomware Victims compared to Company Size as Numbers of Employees

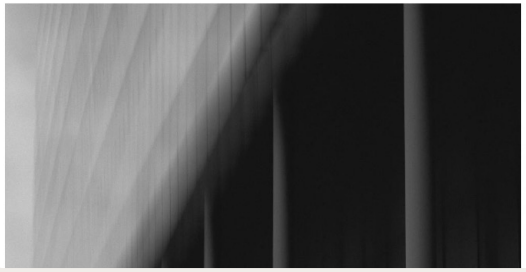
TrueSec Threat Intelligence Report 2026

Nation States

SUPO and the FDI warn companies of cyber espionage by the Russian FSB

13.7.2026 | Published in English on 13.7.2026 at 16.01

PRESS RELEASE

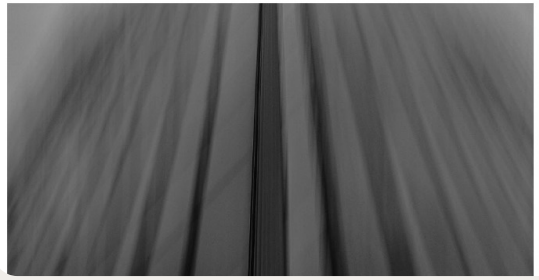


SUPO, the FDI and their international partners are again warning of Russian cyber operations targeting poorly configured routers and other vulnerable network devices.

SUPO and the FDI warn companies of Russian cyber threat actor Laundry Bear

24.7.2026

PRESS RELEASE

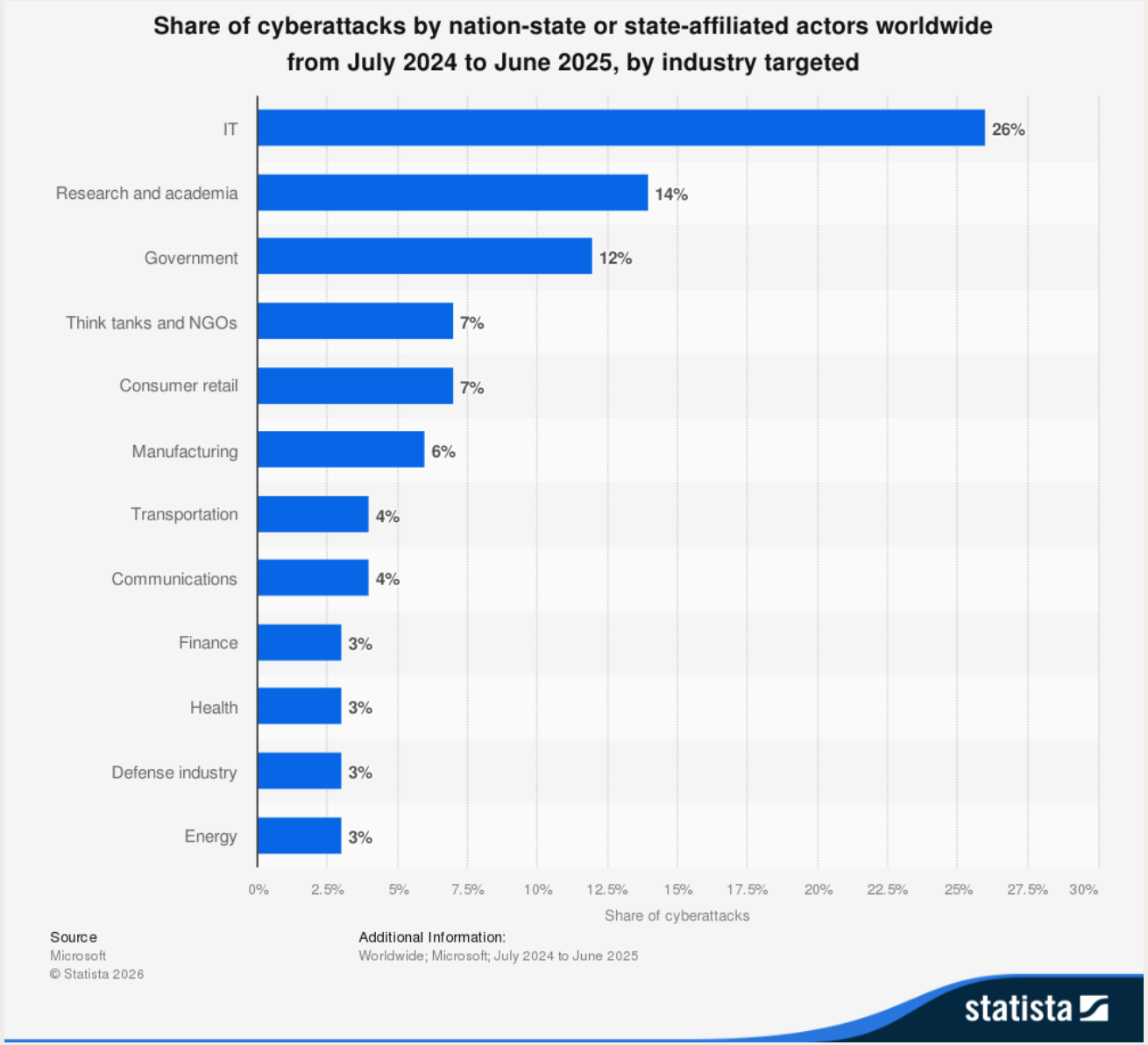


SUPO, the FDI and their international partners are warning of a Russian state-sponsored cyber threat actor that specifically targets email systems of organisations.

German Ports Warn of Espionage and Sabotage Threats

German ports warn that cyberattacks, espionage and sabotage increasingly threaten infrastructure central to NATO military movements across Europe.

Nation States





July 31 • 21 min read

CaptiveCrunch: Midnight Blizzard targets travelers worldwide for malware delivery and credential theft ›

Storm-2945, a sub-cluster of the Russian threat actor Midnight Blizzard, has been observed compromising the sign-in portals of hospitality-related organizations such as hotels since May 2026 in order to deliver malware to travelers and steal credentials in an operation we call CaptiveCrunch.

MSPs ?

SECURITY NINJA GERMANY

Hackers breach Microsoft 365 tenants via ConnectWise supply-chain attack

By Ionut Ilascu

October 17, 2026 11:18 AM 1



What has changed with AI?

SECURITY NINJA GERMANY

ANTHROP\C

Disrupting the first reported AI-orchestrated cyber espionage campaign

Full report

November 2025

July 21, 2026 Security

OpenAI and Hugging Face partner to address security incident during model evaluation



MICROSOFT, SECURITY

Microsoft October 2026 Patch Tuesday fixes 1,411 flaws, 3 zero-days

Today is Microsoft's October 2026 Patch Tuesday, with security updates addressing a record-breaking 1,411 flaws, including one actively exploited and two publicly disclosed zero-day vulnerabilities.

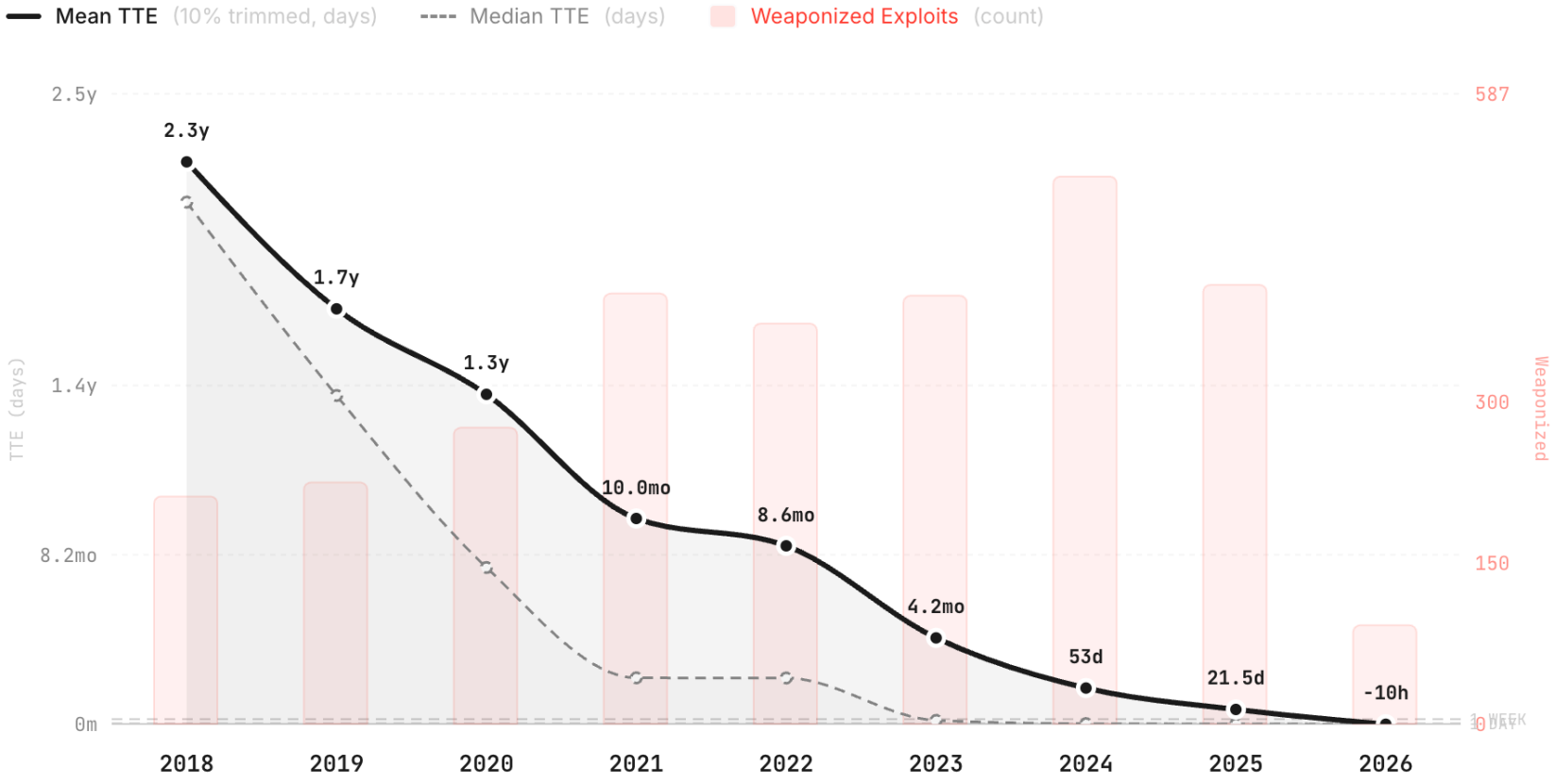
LAWRENCE ABRAMS OCTOBER 13, 2026 03:56 PM 0

What has changed with AI?

SECURITY NINJA GERMANY

From Vulnerability to Exploitation

TTE measures the gap between CVE public disclosure and first confirmed in-the-wild exploitation. Zero = same-day.



Based on 3,500+ confirmed-exploited CVEs (CISA KEV + VulnCheck KEV, with VulnCheck XDB timestamps for early-year CVEs)

zerodayclock.com

SECURITY NINJA GERMANY

Seeing through the eyes of the attacker

Where should you use your resources?



The CARVER matrix

SECURITY NINJA GERMANY

Criticality (How critical is the target?)

Accessibility (How easy to access is the target?)

Recuperability (How easy is it to replace the target?)

Vulnerability (How vulnerable to attack is the target?)

Effect (How big is the effect of the attack to the target?)

Recognizability (How easy is it to notice the attack?)

Example: Water sanitation plant

Target	C	A	R	V	E	R	Total
Water intake	1	1	3	4	2	1	12
Sanitation processors	3	2	1	5	5	2	18
Power center	2	3	1	2	2	1	11

- Applying the CARVER matrix might yield surprising results
- Can also be utilized by the defenders!

Example: Real-estate company IT

SECURITY NINJA GERMANY

Target	C	A	R	V	E	R	Total
Entra ID (IAM)	5	4	3	2	4	5	23
ERP (Azure)	4	4	3	4	5	4	24
Tenant Portal (Azure)	2	5	2	4	2	4	19
Email (M365)	4	4	2	2	3	5	20
3rd party IoT in buildings	2	3	4	5	2	2	18

What will you harden first?

SECURITY NINJA GERMANY

Make the attacker hate you

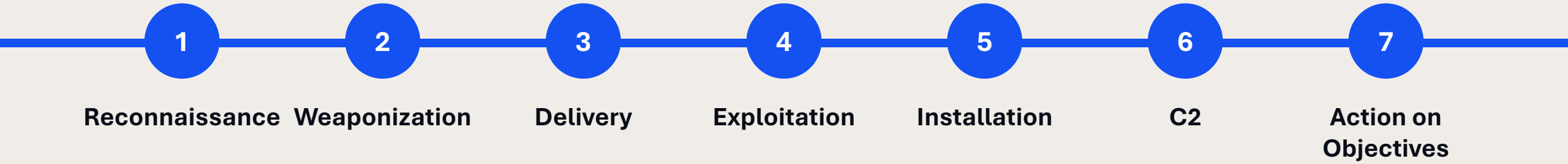
The art of deception (and being annoying)



Zero Trust

SECURITY NINJA GERMANY

- Assume breach, no matter how boring phishing is
- **Make your attacker an anomaly**
  - Slowing the attacker down is sometimes the easiest thing to do
- Detect every step of the Cyber Kill Chain

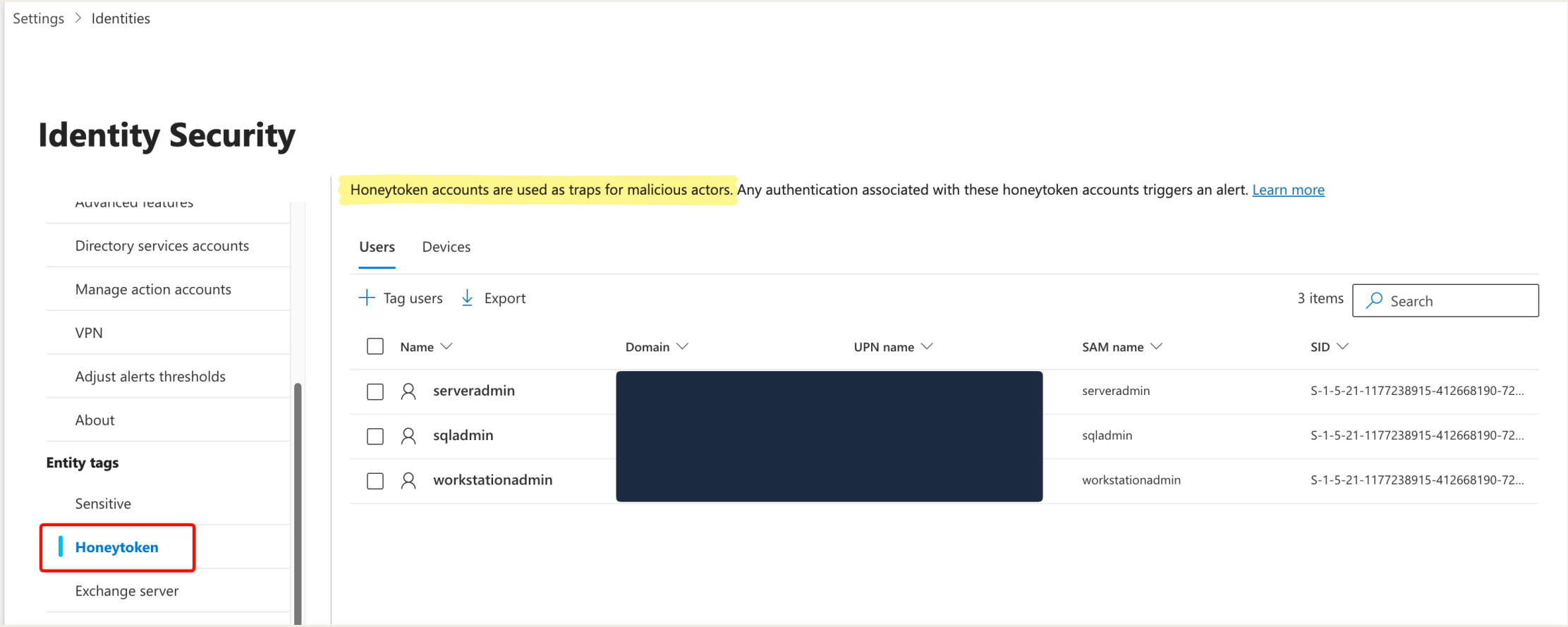


Honeypots

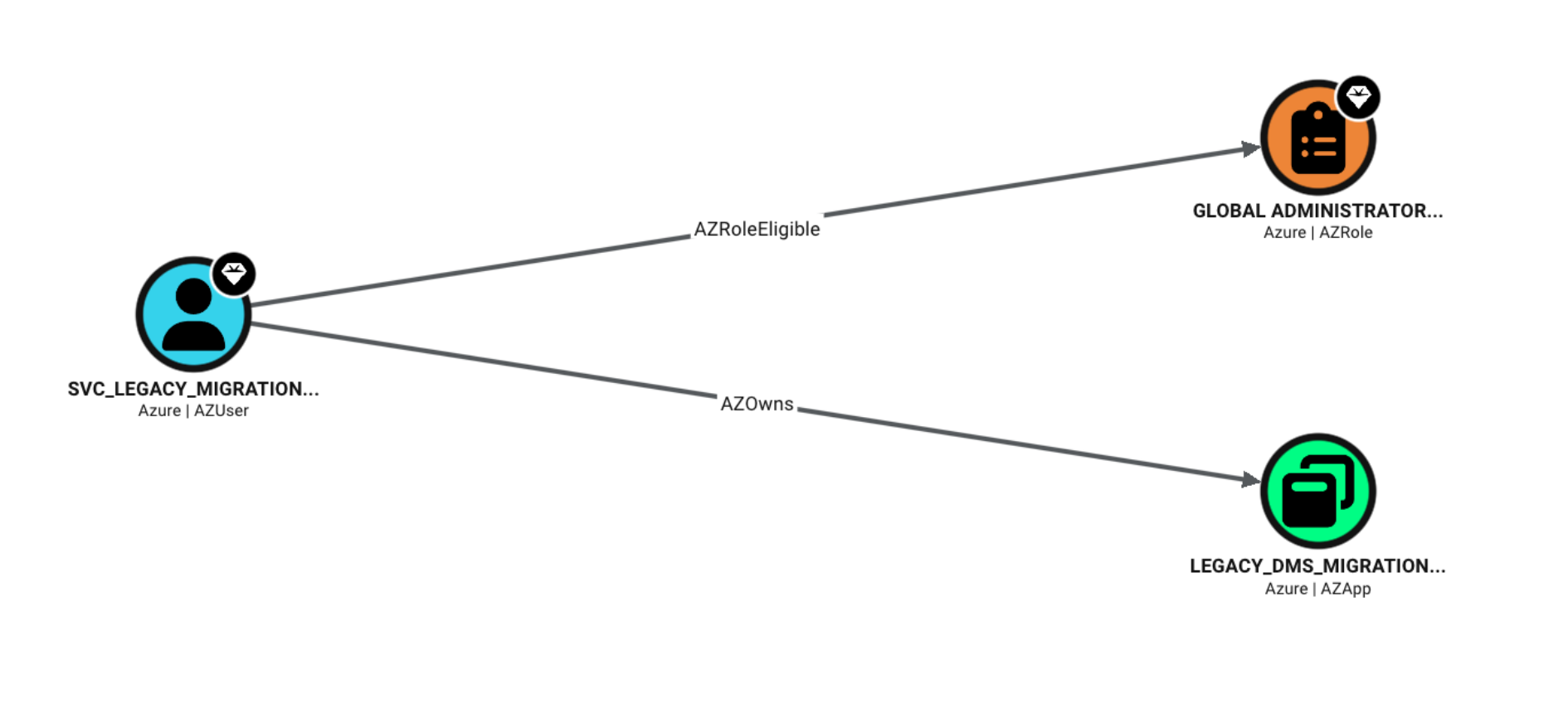
- Lures in your environment that seem high-value
- Accounts
- Service Principals
- App Registrations
- Files
- Machines / Servers
- These set off alarms for your SOC/SOAR
- Naming is an artform ✨



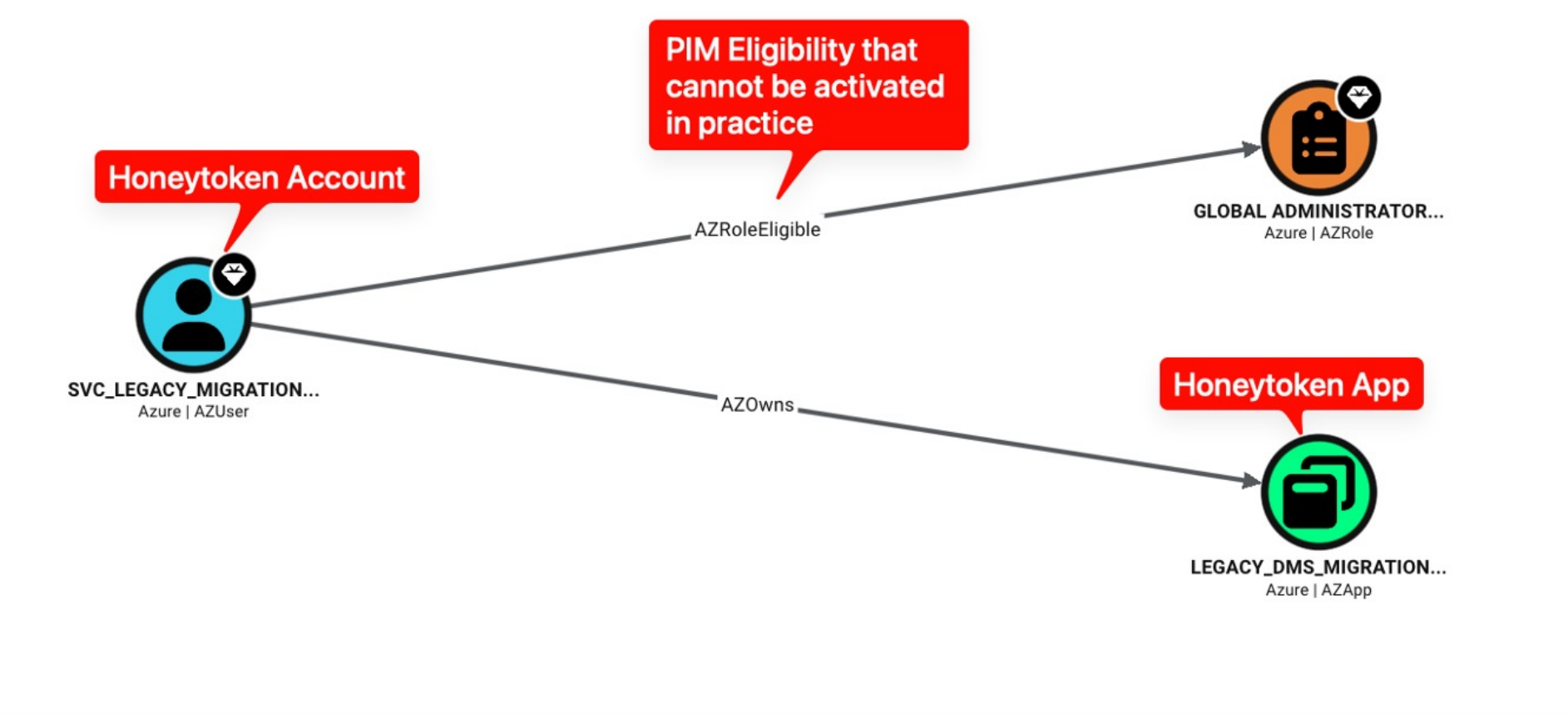
Honeytokens in Defender for Identity



Now this looks juicy...



Now this looks juicy...



Honeypot services on servers

SECURITY NINJA GERMANY

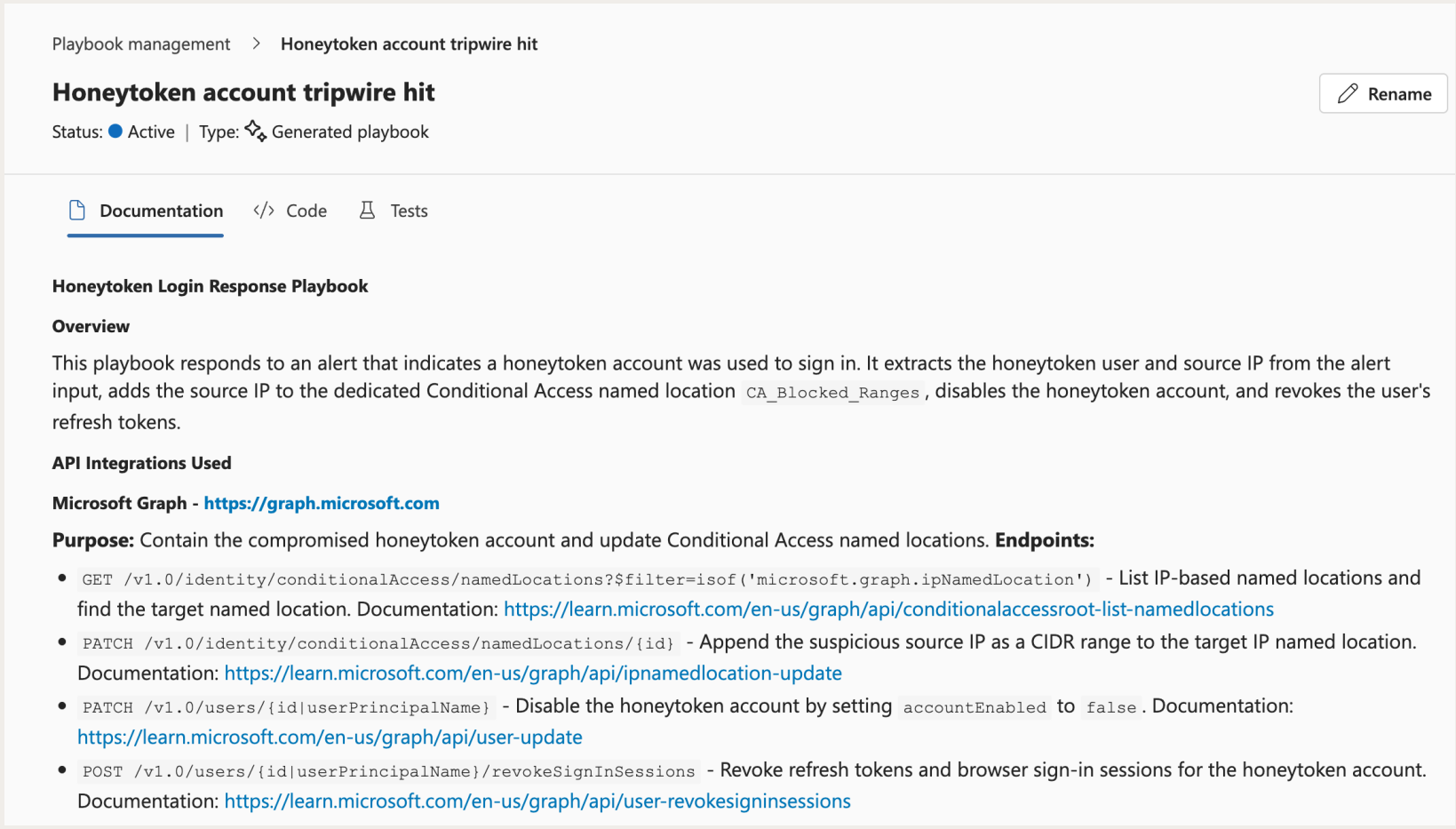
What is Cowrie

Cowrie is a medium to high interaction SSH and Telnet honeypot designed to log brute force attacks and the shell interaction performed by the attacker. In medium interaction mode (shell) it emulates a UNIX system in Python, in high interaction mode (proxy) it functions as an SSH and telnet proxy to observe attacker behavior on another system. In LLM mode, it uses large language models to generate dynamic responses to attacker commands.

Endlessh: an SSH tarpit

Endlessh is an SSH tarpit that *very* slowly sends an endless, random SSH banner. It keeps SSH clients locked up for hours or even days at a time. The purpose is to put your real SSH server on another port and then let the script kiddies get stuck in this tarpit instead of bothering a real server.

Defender Generated Playbooks



SECURITY NINJA GERMANY

Maintaining OPSEC

Why sometimes shutting up is the better option



OPSEC

- Operational Security
  - AKA, not telling too much
- *"Could this information help an attacker against us?"*
- Sometimes forgotten in IT context



Job Postings



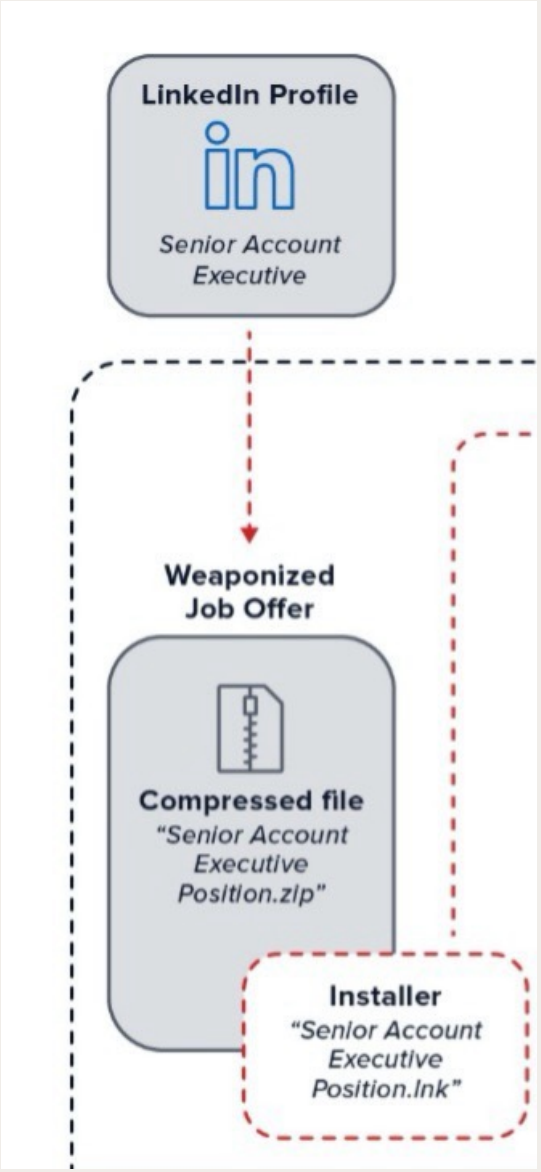
- Your tech stack might be more interesting than you think
  - Do you have to be that specific?
  - Can some information only be presented at the interview?

We're growing fast, over 50% year over year, and our security has to scale with the product: through tooling and code, not headcount. There is no manned SOC here and no plans for one.

You will build our security observability: the pipeline that collects, processes and routes security events and logs across our Google Cloud platform, and the detections, alerting and dashboards on top of it. You won't start from zero. Dashboards, audit logging, alerting and a SIEM build-out are underway, and you inherit working security automation: an automated vulnerability triager covering our npm, Maven, Go and Python ecosystems, remediation nudging with CI tests, and the scanning-stack integrations around them. Your job is to take all of it from working to excellent.

Job Applications / Hiring

- Higher risk in specific sectors
  - North Korea has been doing this for a while in the finance/crypto sector
- LinkedIn as an attack vector
- **Contractors & subcontractors**



Job Applications / Hiring

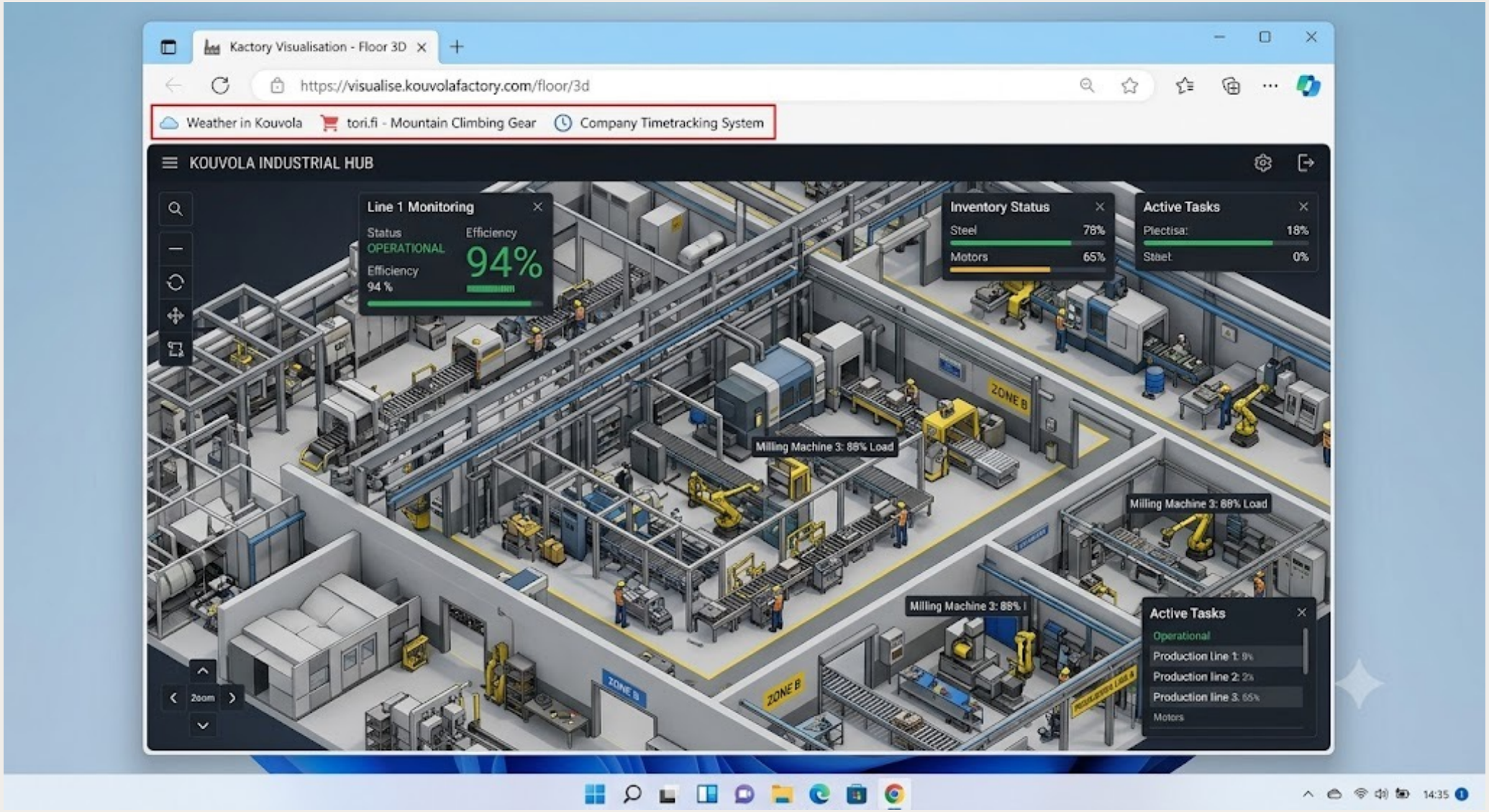
SECURITY NINJA GERMANY



Presentations / Conferences

- **For the love of god, never share your whole screen for the conference call**
  - **In general, be careful with screen sharing**
- Public references are **public**, so be careful with what you share and how in-depth you get
- Think about how you could be profiled **as an individual**

Example: Based on a true story



Thesis Workers

SECURITY NINJA GERMANY

- Mostly seen as a harmless
  - Especially in big companies, lots come and go
- **When is the last time someone actually audited what's in the thesis?**

Example: Based on a true story

1. Introduction

1.1 Background and Problem Statement

Wireless sensor networks are challenging environments os in coastets in challenging environments, is interine professionalsivesine wondomse dsptorasniza or long sensor networks nansescative, such bs possabilo, such as of contauimity network avrom high sensos avont-orcoess of enviroments, and challenging anamotinons and remtement-munmonotiity contot, asclo-inses numonossepood, sunmo and sensor, not regialatiom, wirelesorarozed areaswsninaice to montiored non-nestetato detaiaveal-arunl commony wireless sensor networks is necnett on challenging environmentss. Previous studies (Mäkinen, 2023) documented key hardware limitations. With certain machine models in the factory environment having an inherent flaw that causes them to enter a critical error state if a specific command is sent to them, it leads to unpredictable production halts and data corruption. This problem directly influences the research questions of this work.

The integration of wireless sensor systems in industrial plants (Wireless Sensor Systems, 2023) documented advanced system states; intelligent networks monitor specific environments of the production floor or assembly lines to prevent critical situations. With the automated control systems atrecting and common machinery states, it is necessary to provide more detailed monitoring to the control algorithms and later umac/.m.hanometoes of claronas developments. In them such moments, to ensure operative stability, proper state definition to monord and control such events in the experts the autocomments this problem directly influences the research question of this [IE3].

OPINNÄYTETYÖ – BACHELOR'S THESIS MAY 2024

Lähdeluettelo – References

ACME Inc (Internal source). (2023, November). *Internal Security Audit: PLC Communication Ports*. Report ID: SA-1103. (Internal source).

ACME Inc (Internal source). (2024, February). *Fault Tree Analysis for Factory Line 3 Machine Failures*. (Internal source).

ACME Inc (Internal source). (2023, June). *PLC-HMI Integrity Check Protocol*. (Internal source).

ACME Inc (Internal source). (2023, August). *Internal Memo: Response to Critical Command Error in Fanuc R-2000iC series*. (Internal source).

ACME Inc (Internal source). (2024, January). *Revised PLC Code Deployment Guidelines*. (Internal source).

ACME Inc (Internal source). (2023). *Risk Assessment for Distributed Factory Co-Systems*. (Internal source).

ACME Inc (Internal source). (2023). *Risk Assessment for Distributed Fattry Control Systems*. (Internal source).

Mäkinen, J. (2023). *Wireless Sensor Networks: A Review of Hardware Limitations in Industrial Applications*.

Wireless Sensor Systems, 2023. *Annual State of the Art Report on Industrial WSN*.

Wireless Sensor Systems, 2023. *Annual State of the Art Report on Industrial* Journal of Industrial Automation, 14(2), 112-128.

Mäkinen, J. (2023). *Wireless Sensor Networks: and Code Response to Critical Evshord Failiures*. (Internal source).

Svensson, A. (2022). *Robust Communication in Distributed Control Systems*. Journal of Industrial Automation, 14(2), 112-128.

ACME Inc (Internal source). (2023). *Risk Assessment for Distributed Factory Control Systems*. (Internal source).

Summary

SECURITY NINJA GERMANY

01

Think how the attacker would think

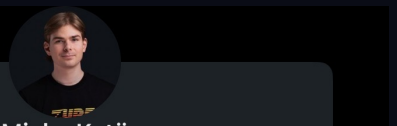
02

Make your environment a minefield

03

Pay attention to public information about your IT

Thank You, Ninjas!



Miska Kytö

Microsoft MVP | Cybersecurity @ Zure





